

Dalla NIS alla NIS 2: L'evoluzione della cybersecurity obbligatoria per le aziende europee

Gruppo di lavoro: DoSBusters

Natale Mastrogiacomo, S345071
Johnprice Osagie, S344613
Francesco Pusceddu, S349318
Francesco Ambrosino, S354781
Federico Farci, S347748
Ivan Guariento, S347630

Keywords: Direttiva NIS; Direttiva NIS 2; Sicurezza informatica; Cybersecurity

1 Introduzione

Negli ultimi anni la cybersecurity è diventata una priorità strategica per l'Unione Europea, in risposta alla crescente dipendenza delle economie e delle società europee da reti e sistemi informativi interconnessi. La digitalizzazione diffusa dei servizi essenziali, delle infrastrutture critiche e delle catene di fornitura ha ampliato in modo significativo la superficie di attacco, rendendo possibile che un singolo incidente informatico produca effetti a cascata su più settori e oltre i confini nazionali. In questo scenario, la sicurezza delle reti non può più essere affrontata esclusivamente a livello tecnico o nazionale, ma richiede un coordinamento sistemico a livello europeo [1, 2].

In tale contesto si inserisce l'adozione della Direttiva (UE) 2016/1148, nota come Direttiva NIS, entrata in vigore nel 2016 come primo quadro normativo europeo specificamente dedicato alla sicurezza delle reti e dei sistemi informativi. La direttiva ha introdotto obblighi di gestione del rischio e di notifica degli incidenti per gli operatori di servizi essenziali e per alcuni fornitori di servizi digitali, oltre a meccanismi di cooperazione tra Stati membri, come il Cooperation Group e la rete dei Computer Security Incident Response Teams (CSIRT)¹[1].

Nonostante i progressi introdotti, la valutazione ufficiale della Direttiva NIS ha evidenziato diversi limiti strutturali. In particolare, il suo ambito di applicazione è risultato progressivamente inadeguato rispetto all'evoluzione del contesto digitale europeo. Numerosi settori oggi fortemente digitalizzati e interdipendenti non rientravano nel perimetro della direttiva oppure vi rientravano in modo disomogeneo. Inoltre, l'ampia discrezionalità lasciata agli Stati membri nel processo di identificazione degli operatori di servizi essenziali ha prodotto una significativa frammentazione normativa, con trattamenti differenti per entità comparabili in Paesi diversi [1, 3].

Un ulteriore limite riguarda la mancanza di armonizzazione dei requisiti di sicurezza e delle procedure di notifica degli incidenti. Gli Stati membri hanno adottato approcci differenti nella definizione delle misure tecniche e organizzative e nei criteri temporali per la segnalazione degli incidenti, riducendo l'efficacia di una risposta coordinata a livello europeo. Anche i meccanismi di supervisione e di applicazione delle sanzioni si sono dimostrati deboli e disomogenei, mentre la condivisione delle informazioni tra autorità nazionali e tra settore pubblico e privato è rimasta spesso limitata e non sistematica [1, 3].

L'aumento delle interdipendenze tra settori economici e infrastrutture critiche ha ulteriormente accentuato tali criticità. La crescente interconnessione tra sistemi informativi fa sì che

¹Organismi di coordinamento tra Stati e istituzioni che servono a condividere informazioni sugli incidenti informatici, migliorare la prevenzione e favorire una risposta rapida e coordinata agli attacchi di sicurezza.

la compromissione di un singolo attore possa generare effetti a catena su altri servizi essenziali, amplificando l'impatto economico e sociale degli incidenti informatici. Eventi recenti, come l'incremento degli attacchi ransomware² e le vulnerabilità emerse durante la pandemia di COVID-19, hanno evidenziato come le minacce cyber possano sfruttare situazioni di crisi per colpire infrastrutture e servizi fondamentali [1].

Alla luce di queste criticità, l'Unione Europea ha avviato un processo di revisione della Direttiva NIS, culminato nella proposta e successiva adozione della Direttiva NIS 2. Il nuovo quadro normativo mira a superare le carenze della NIS attraverso un ampliamento del campo di applicazione, una maggiore armonizzazione degli obblighi di sicurezza e un rafforzamento dei meccanismi di supervisione e cooperazione. La NIS 2 rappresenta quindi un passaggio chiave nel percorso europeo volto a trasformare la cybersecurity da insieme di buone pratiche volontarie a requisito strutturale per la sicurezza dei sistemi informativi delle organizzazioni [1, 4, 2].

2 Descrizione

2.1 Che cos'è la Direttiva NIS 2

La Direttiva (UE) 2022/2555, nota come NIS 2, costituisce il principale strumento normativo dell'Unione Europea volto a garantire un livello elevato e uniforme di sicurezza delle reti e dei sistemi informativi nel mercato interno [5, 1].

L'obiettivo della NIS 2 è rafforzare la resilienza cyber delle organizzazioni pubbliche e private che forniscono servizi essenziali o rilevanti per l'economia e la società, riducendo la frammentazione normativa tra Stati membri attraverso l'introduzione di requisiti minimi comuni in materia di gestione del rischio, sicurezza dei sistemi informativi e notifica degli incidenti [1]. A tal fine, la direttiva distingue tra Essential Entities e Important Entities³, prevedendo obblighi di sicurezza sostanzialmente analoghi ma differenti modalità di supervisione, con l'obiettivo di garantire un'applicazione proporzionata ed efficace delle misure [5, 4].

2.2 Differenze tra la Direttiva NIS e la Direttiva NIS 2

Rispetto alla Direttiva NIS del 2016, la NIS 2 introduce modifiche sostanziali volte a superare i limiti emersi nella fase di attuazione nazionale. Una prima differenza rilevante riguarda il campo di applicazione: mentre la NIS originale si concentrava su un numero ristretto di settori e lasciava agli Stati membri il compito di identificare gli operatori di servizi essenziali, la NIS 2 adotta un approccio più ampio e uniforme, includendo un numero significativamente maggiore di settori e organizzazioni considerate critiche per il funzionamento della società e dell'economia europea [1, 5].

Un ulteriore elemento di discontinuità concerne il livello di armonizzazione normativa. La Direttiva NIS lasciava ampi margini di discrezionalità agli Stati membri nella definizione dei requisiti di sicurezza e degli obblighi di notifica, generando una forte frammentazione. La NIS 2 riduce tali discrezionalità introducendo requisiti più dettagliati e comuni, rafforzando al contempo i meccanismi di supervisione ed enforcement attraverso un quadro sanzionatorio più chiaro e dissuasivo [1, 4]. Nel complesso, la nuova direttiva segna il passaggio da un approccio prevalentemente reattivo a uno più proattivo e orientato al rischio, che riconosce il carattere sistemico delle minacce informatiche [4].

²Attacchi che consistono nel bloccare l'accesso ai dati di un sistema informativo tramite la loro cifratura, rendendoli inutilizzabili, e quindi richiedere un pagamento per ripristinarli.

³Categorie di organizzazioni individuate dalla direttiva NIS 2 in base alla loro importanza per il funzionamento della società e dell'economia. Le prime svolgono servizi essenziali e sono soggette a controlli più stringenti, mentre le seconde hanno un ruolo rilevante ma con obblighi di supervisione meno severi.

2.3 Impatto organizzativo e criticità

L'adozione della Direttiva NIS 2 comporta un impatto significativo sull'organizzazione interna delle entità soggette alla normativa, richiedendo l'integrazione della cybersecurity nei processi decisionali e gestionali. La direttiva introduce obblighi formali di gestione del rischio, documentazione, continuità operativa e risposta agli incidenti, rafforzando il ruolo degli organi di gestione nella supervisione delle misure di sicurezza [5, 1]. Tale approccio mira a colmare il divario tra decisioni strategiche e implementazione tecnica, promuovendo una maggiore consapevolezza dei rischi informatici a livello dirigenziale [4].

Tuttavia, la NIS 2 presenta anche alcune criticità. La complessità degli obblighi introdotti può comportare costi organizzativi e amministrativi rilevanti, soprattutto per le organizzazioni di dimensioni medio-piccole o appartenenti a settori meno maturi dal punto di vista della cybersecurity. Inoltre, nonostante la riduzione delle discrezionalità nazionali, permangono margini di interpretazione nell'attuazione e nell'enforcement che potrebbero generare differenze applicative tra Stati membri. L'efficacia complessiva della direttiva dipenderà quindi dalla capacità delle organizzazioni di superare un approccio meramente formale alla compliance e di integrare in modo sostanziale le misure di sicurezza nei processi operativi [1].



Figure 1: Infografica sintetica del percorso di adeguamento alla Direttiva NIS 2 in quattro fasi: identificazione dei soggetti obbligati, implementazione delle misure di gestione del rischio, pianificazione della risposta ai data breach e monitoraggio continuo.

3 Analisi Tecnica

L'efficacia della Direttiva NIS 2 non risiede solo nell'estensione del perimetro normativo, ma nella definizione di un set minimo di misure tecniche obbligatorie che trasformano la gestione del rischio da "buona pratica" a requisito tecnologico stringente [4]. L'approccio tecnico si basa sul concetto di sicurezza proattiva, imponendo alle entità l'adozione di soluzioni conformi allo stato dell'arte e standard tecnici riconosciuti [5].

3.1 Misure di Igiene Informatica e Zero Trust Architecture

Il cuore operativo della Direttiva NIS 2 è l'Articolo 21, che elenca le misure fondamentali di gestione del rischio. Dal punto di vista architetturale, la normativa spinge verso l'abbandono della sicurezza perimetrale tradizionale:

- **Zero Trust Architecture:** La direttiva richiede misure tecniche che minimizzino l'impatto degli incidenti. In questo contesto, l'adozione del modello *Zero Trust* diventa lo standard di riferimento per garantire che ogni richiesta di accesso sia verificata e autenticata, indipendentemente dalla provenienza della connessione [6].
- **Autenticazione Forte e Crittografia:** È reso obbligatorio l'uso di soluzioni di autenticazione a più fattori (MFA) per l'accesso a reti e sistemi sensibili, unitamente all'impiego di crittografia *end-to-end* per proteggere la riservatezza dei dati in transito e a riposo [5].

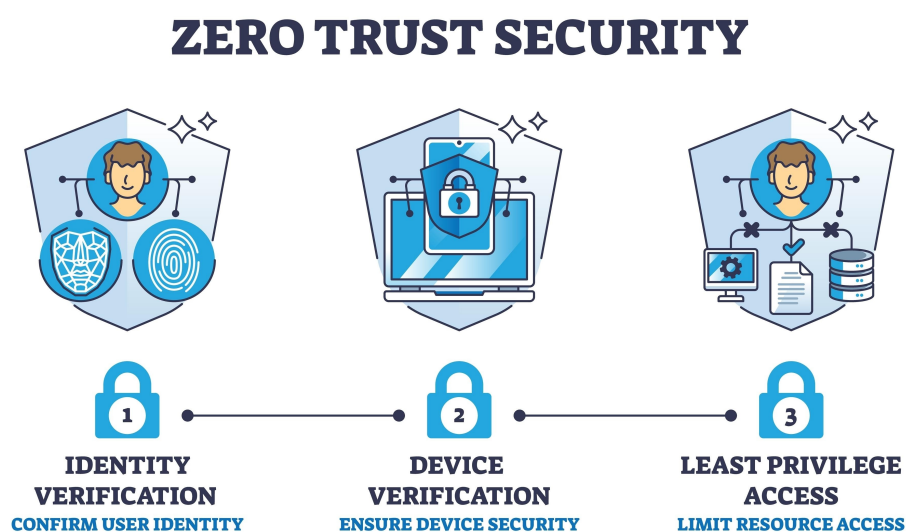


Figure 2: Schema dei principi fondamentali dell'architettura Zero Trust (verifica continua dell'identità, sicurezza del dispositivo e accesso con privilegi minimi), che costituisce il modello tecnico di riferimento per la gestione del rischio nella Direttiva NIS 2.

3.2 La Sicurezza della Supply Chain e lo standard Software Bill of Materials (SBOM)

Uno degli aspetti più innovativi della NIS 2 è l'estensione della responsabilità tecnica alla catena di approvvigionamento. Le organizzazioni devono valutare i rischi legati ai rapporti con i fornitori e ai prodotti ICT utilizzati [7]. Tecnicamente, questo si traduce nell'adozione della Software Bill of Materials (SBOM), un inventario formale dei componenti software che permette di identificare rapidamente la presenza di vulnerabilità note in librerie di terze parti, mitigando i rischi di attacchi a cascata [7, 3].

3.3 Meccanismi di Notifica e Incident Reporting

La gestione degli incidenti impone requisiti temporali stringenti che rendono indispensabile l'adozione di sistemi di monitoraggio automatizzati. Le linee guida tecniche per l'implementazione prevedono un flusso di notifica a tre stadi [8]:

1. **Pre-allarme (24 ore):** Una segnalazione tempestiva al CSIRT di riferimento in caso di incidenti significativi che potrebbero avere impatti transfrontalieri [5].
2. **Notifica dell'Incidente (72 ore):** Una valutazione tecnica più approfondita che includa una stima della gravità, dell'impatto e, ove disponibili, gli indicatori di compromissione (IoC) [9, 8].

3. **Relazione Finale (30 giorni):** Un report dettagliato contenente l'analisi delle cause profonde (*Root Cause Analysis*) e le misure correttive implementate [5].

3.4 Vulnerability Disclosure Europea

Per armonizzare la risposta alle minacce, la NIS 2 istituisce un quadro coordinato per la divulgazione delle vulnerabilità (Coordinated Vulnerability Disclosure (CVD)). Il supporto tecnico è fornito dall'ENISA attraverso un database europeo delle vulnerabilità, che funge da registro centralizzato per le falle di sicurezza nei prodotti ICT, permettendo alle entità di ricevere informazioni tecniche verificate e ridurre i tempi di esposizione [1, 8].

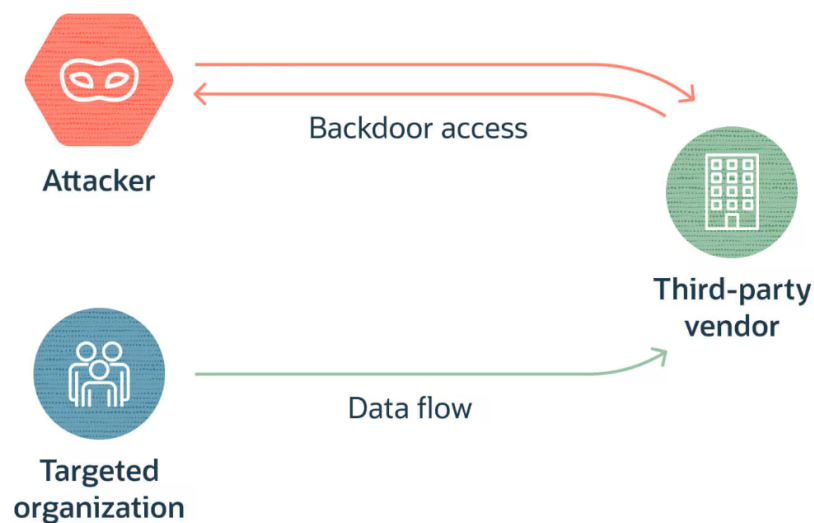


Figure 3: Illustrazione semplificata di un attacco alla supply chain: l'attaccante compromette un fornitore di terze parti per ottenere un accesso indiretto (backdoor) ai dati dell'organizzazione bersaglio, evidenziando la criticità delle dipendenze esterne.

4 Casi reali

Lo studio analizzato spiega bene la transizione tra NIS e NIS 2 attraverso tre "famiglie" di incidenti che, negli ultimi anni, hanno evidenziato un salto di scala e complessità delle minacce, l'impatto operativo su servizi essenziali e la difficoltà pratica di stabilire quando scatta l'obbligo di notifica, soprattutto nei casi in cui il danno non è immediatamente osservabile [9].

4.1 SolarWinds: attacco di *supply chain* e impatto "transnazionale"

Il caso SolarWinds è spesso richiamato come paradigma degli attacchi moderni alla supply chain: non si colpisce soltanto una singola organizzazione, ma si compromette un anello (ad esempio un fornitore software) per ottenere un effetto "a cascata" su una pluralità di vittime, anche molto eterogenee per dimensione e settore. Questo tipo di incidente rende immediato il limite di un'impostazione normativa pensata principalmente per la sicurezza del singolo operatore: nella realtà attuale, la superficie d'attacco e il rischio sono fortemente determinati dalle dipendenze tecnologiche e contrattuali, e quindi dalla filiera.

4.2 Ransomware e sanità: quando l'impatto è la continuità del servizio

Una seconda famiglia di incidenti è quella dei ransomware su organizzazioni che erogano servizi essenziali, come sanità, infrastrutture o servizi pubblici. In questi contesti l'effetto non si misura soltanto in perdita di dati o costi di ripristino, ma in indisponibilità del servizio e, quindi, in impatto diretto sugli utenti finali. Lo studio cita esplicitamente un caso in cui, a seguito di un

attacco ransomware, un ospedale non è stato in grado di ammettere nuovi pazienti per diversi giorni.

4.3 Microsoft Exchange / *Hafnium*: il problema del danno non ancora osservabile

Il terzo caso è utile non tanto per l'impatto immediato sull'operatività, quanto per la lezione che offre sul tema delle soglie di notifica. Nello sfruttamento delle vulnerabilità di Microsoft Exchange (campagna spesso associata a "Hafnium"), il punto critico è che l'organizzazione può trovarsi in una condizione di rischio elevato senza poter dimostrare subito con certezza se vi sia stata effettiva compromissione dei dati o un accesso non autorizzato. In altre parole: la presenza di una vulnerabilità sfruttabile, e la possibilità concreta di accesso, pongono un dilemma pratico sul quando segnalare.

5 Conclusioni e discussione

Il passaggio dalla Direttiva NIS alla NIS 2 segna un momento di svolta fondamentale nella strategia europea per la sicurezza cibernetica. Come evidenziato nell'analisi, non si tratta di un semplice aggiornamento di documentazione dal punto di vista burocratico, bensì l'espressione di un cambiamento strutturale, in cui la cybersecurity diventa oggi un requisito essenziale per la sicurezza sociale ed economica dell'Unione [1, 2].

5.1 L'estensione del perimetro normativo

Una delle innovazioni più rilevanti, come anticipato, è l'estensione del campo di applicazione a settori economici che, pur non essendo tradizionalmente associati alle infrastrutture critiche digitali, risultano oggi fortemente dipendenti dai sistemi informativi. La NIS 2 include nuovi ambiti quali la gestione dei rifiuti, la produzione e distribuzione alimentare, i servizi postali e manifatturieri [5]. Tale adeguamento fa comprendere come anche i servizi apparentemente "non tecnologici" possano generare impatti significativi sulla continuità operativa e sulla sicurezza collettiva [4].

5.2 Il cambio di paradigma tecnico e operativo

L'efficacia della NIS 2 non risiede solo nell'aumento dei soggetti coinvolti, ma anche nei nuovi approcci alla difesa. L'analisi tecnica ha mostrato come la direttiva imponga l'abbandono della sicurezza perimetrale in favore di approcci *Zero Trust* [6] e di una gestione proattiva del rischio. L'introduzione di strumenti come la *Software Bill of Materials* (SBOM) e l'obbligo di valutare la sicurezza della *supply chain* rispondono direttamente alle vulnerabilità emerse in casi reali come SolarWinds, dove il rischio è dettato dalle dipendenze tecnologiche più che dalla singola infrastruttura [7, 9].

5.3 Sfide future

In conclusione, se da un lato le modifiche introdotte promettono una risposta europea più rapida e coordinata [8], dall'altro l'impatto organizzativo rimane la sfida principale. Il successo della NIS 2 dipenderà dalla capacità delle entità, specialmente quelle di nuova inclusione, di superare un approccio meramente formale alla *compliance*, integrando la sicurezza informatica nei processi decisionali e operativi dell'organizzazione [3].

Glossary

Coordinated Vulnerability Disclosure (CVD) Processo coordinato di segnalazione e divulgazione delle vulnerabilità di sicurezza, volto a ridurre i rischi per utenti e organizzazioni attraverso una gestione responsabile delle informazioni. 5

Direttiva NIS Prima normativa europea sulla sicurezza delle reti e dei sistemi informativi, adottata nel 2016, che ha introdotto obblighi di gestione del rischio e di notifica degli incidenti per operatori di servizi essenziali e fornitori digitali. 1

Direttiva NIS 2 Normativa europea adottata nel 2022 che rafforza e amplia la Direttiva NIS, introducendo un campo di applicazione più esteso, requisiti di sicurezza armonizzati e meccanismi di supervisione e sanzione più stringenti. 2

Essential Entities Categorie di organizzazioni individuate dalla Direttiva NIS 2 che forniscono servizi essenziali per la società e l'economia e sono soggette a obblighi di sicurezza e supervisione rafforzati. 2

Important Entities Categorie di organizzazioni definite dalla Direttiva NIS 2 che svolgono un ruolo rilevante per il mercato e la società, soggette a requisiti di sicurezza simili alle essential entities ma con modalità di supervisione meno stringenti. 2

Incident Reporting Insieme delle procedure previste dalla Direttiva NIS 2 per la notifica tempestiva degli incidenti di sicurezza alle autorità competenti, secondo tempistiche e livelli di dettaglio predefiniti. 4

Software Bill of Materials (SBOM) Inventario strutturato dei componenti software utilizzati in un prodotto o servizio, impiegato per identificare vulnerabilità note e gestire i rischi legati alla supply chain digitale. 4

Zero Trust Architecture Modello di sicurezza che presuppone l'assenza di fiducia implicita all'interno della rete, imponendo la verifica continua di identità, dispositivi e accessi indipendentemente dalla loro posizione. 3

References

- [1] European Commission. Impact assessment accompanying the proposal for a directive on measures for a high common level of cybersecurity across the union. Technical Report SWD(2020) 345 final, European Commission, 2020. Accessed: 2025-12-27.
- [2] Stephan Schmitz-Berndt. The proposals for a nis 2.0 directive: Advancing eu cybersecurity regulation. *SSRN Electronic Journal*, 2022. Accessed: 2025-12-27.
- [3] ICF, Wavestone, and CEPS. Study to support the review of directive (eu) 2016/1148 concerning measures for a high common level of security of network and information systems across the union. Technical report, European Commission, 2021. Accessed: 2025-12-27.
- [4] European Commission. Proposal for a directive on measures for a high common level of cybersecurity across the union. Technical Report COM(2020) 823 final, European Commission, 2020. Accessed: 2025-12-27.
- [5] European Union. Directive (eu) 2022/2555 on measures for a high common level of cybersecurity across the union. <https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:32022L2555>, 2022. Accessed: 2025-12-27.
- [6] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. Zero trust architecture. Technical Report SP 800-207, National Institute of Standards and Technology (NIST), 2020. Standard tecnico di riferimento per l'architettura Zero Trust.
- [7] ENISA. Good practices for supply chain cybersecurity. Technical report, European Union Agency for Cybersecurity, 2023.
- [8] ENISA. Nis2 technical implementation guidance. Technical report, European Union Agency for Cybersecurity, 2025.
- [9] Sandra Schmitz-Berndt. Defining the reporting threshold for a cybersecurity incident under the nis directive and the nis 2 directive, 2023.